

CYBE 435

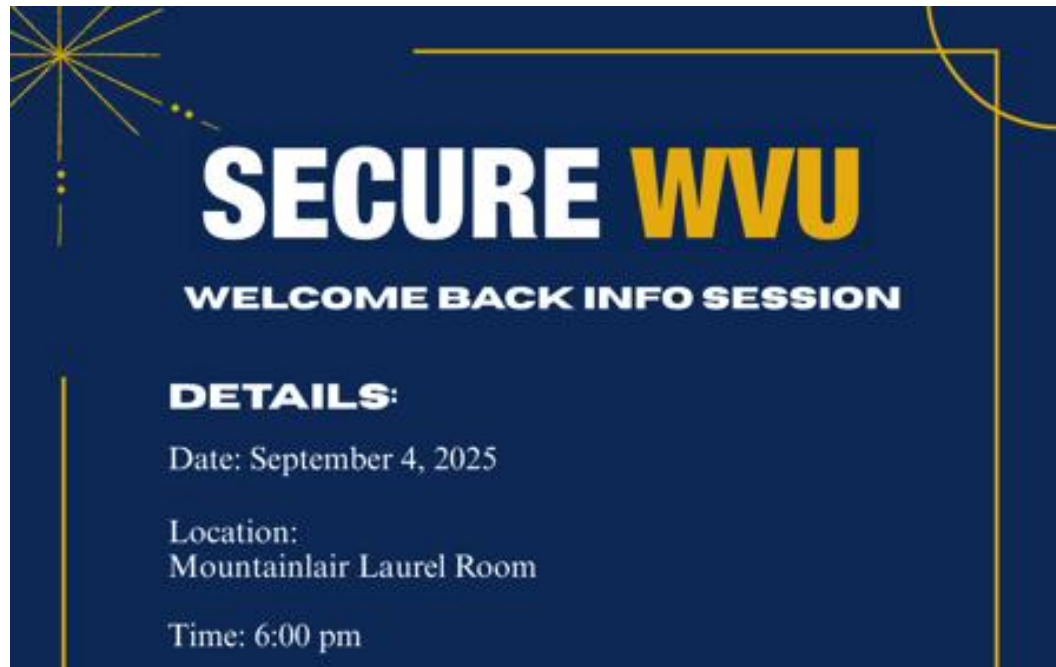
Computer Incident Response

Lecture 5:

Detection through Log Analysis

Announcements

- Quiz #1 is complete
 - The class did very well (average was above 4.5)
- Incident Management Policy is due by next Tuesday, Sept. 9 at 11:59pm



Primary ways of detecting Cyber Incidents

- Log and Event Monitoring
- End-point or Host-monitoring
- Network Traffic Analysis
- Manual Observation and Reporting
- Security Testing and Intelligence Correlation

Log Analysis

- System, Application and Network Logs are collected and monitored for unusual patterns
- Some typical patterns which trigger alerts
 - Repeated Login Failures
 - Sudden privilege changes
 - Connections from usual locations/IP addresses
 - Unexpected processes executing
- The task of going through logs is usually automated, because the information is so extensive
 - Centralized Security Information and Event Management (SIEM) systems

Example: Target 2013 Point-of-Sale Brach

- In late 2013, attackers infiltrated Target's network through a third-party HVAC contractor
 - They installed malware on POS terminal (check-out registers) to steal customer's credit card data
- Target had an SIEM in place that was aggregating system and network logs. The system had actually detected the following:
 - Malware detection events on POS terminals (unexpected binary files executed)
 - Outbound network logs showing traffic from POS terminals to unfamiliar external servers
 - Authentication logs showing account logins to servers that they had not previously accessed

In the Target case, the alerts generated from the logs were not acted upon

- Result: 40 million consumer credit card numbers were exposed
- Total cost: Approximately \$292M
 - Legal settlements
 - Technology upgrades
 - Adverse publicity
 - Insurance covered only about \$90M

University of California – San Francisco (2020)

- A Happier Outcome
- Attackers attempted to deploy ransomware in the UCSF medical school network
- The Security Operations Center (SOC) observed
 - Active Directory and Windows Event logs showed a spike in privileged account login attempts from a single workstation
 - Logs also showed the creation of new scheduled tasks and execution of shell scripts that was unusual for the users involved
 - Events were detected in near-real time and the affected networks were isolated before encryption commands could be executed across the network.
- Outcome: Only a small number of systems were affected

What types of log activity to look for

- Brute force login
 - Multiple failed login attempts from the same IP or account
- Privilege escalation
 - Sudden addition of new users to “admin” or “root” privilege groups
- Lateral movement
 - Remote desktop (RDP/SSH) connections between machines that don’t normally talk
 - Unexpected Kerberos ticket requests
- Data exfiltration
 - Unusually large outbound data transfers
- Ransomware
 - Unusually large number of encryption events
- Web Exploits
 - HTTP requestions SQL keywords
 - Repeated probing of endpoints.

Security Information and Event Management (SIEM) platforms

- Functions
 - Log collection and normalization
 - Real-time event correlation and analysis
 - Issues Incident Alerts
 - Human security personnel can follow up on a limited number of items
 - Threat Intelligence Integration
- Some Commercial SIEM Tools
 - Splunk
 - Microsoft Sentinel
 - RSA Netwitness
- Freeware SIEM: Wazuh